

Medsforless — Phase 1 Architecture & Comments Review

Deterministic MVP — Before Code Review
QA Scenarios v1.1 + Automation Guide + Security Review

Date: 2026-09-14 | Version: 1.0 | Scope: Webhook Auth, Queue, DB, FAQ, Office Hours, Human Handoff
Explicitly NOT in Phase 1: No LLM (Phase 2), No Media Intake (Phase 3), No Auto Quoting (Phase 4-6)
Exit Criteria: No duplicate replies (wamid PK), Verified redacted logs, Replay tests pass

Table of Contents

1. Executive Summary
2. High-Level Architecture
3. Data Flow — 12 Steps
4. Intent Map — 22 QA Scenarios to Phase 1 Actions
5. Database Schema & Security Controls
6. Phase Boundaries
7. Comments Review — What is Excellent
8. Critical Gaps for Phase 1
9. Missing Scenarios for Production
10. Architecture Recommendations for Code
11. Questions Before Code
12. Final Recommendation

1. Executive Summary

QA doc v1.1 (22 intents, 985 lines) is significantly better than v1.0 and the original Hermes/Claude automation guide. It correctly defines 22 intents, 4 escalation priorities (URGENT 1h, HIGH 4h, NORMAL 24h, LOW 48h), and strict formatting rules (Rules #1-13) that prevent medical advice and pricing hallucinations.

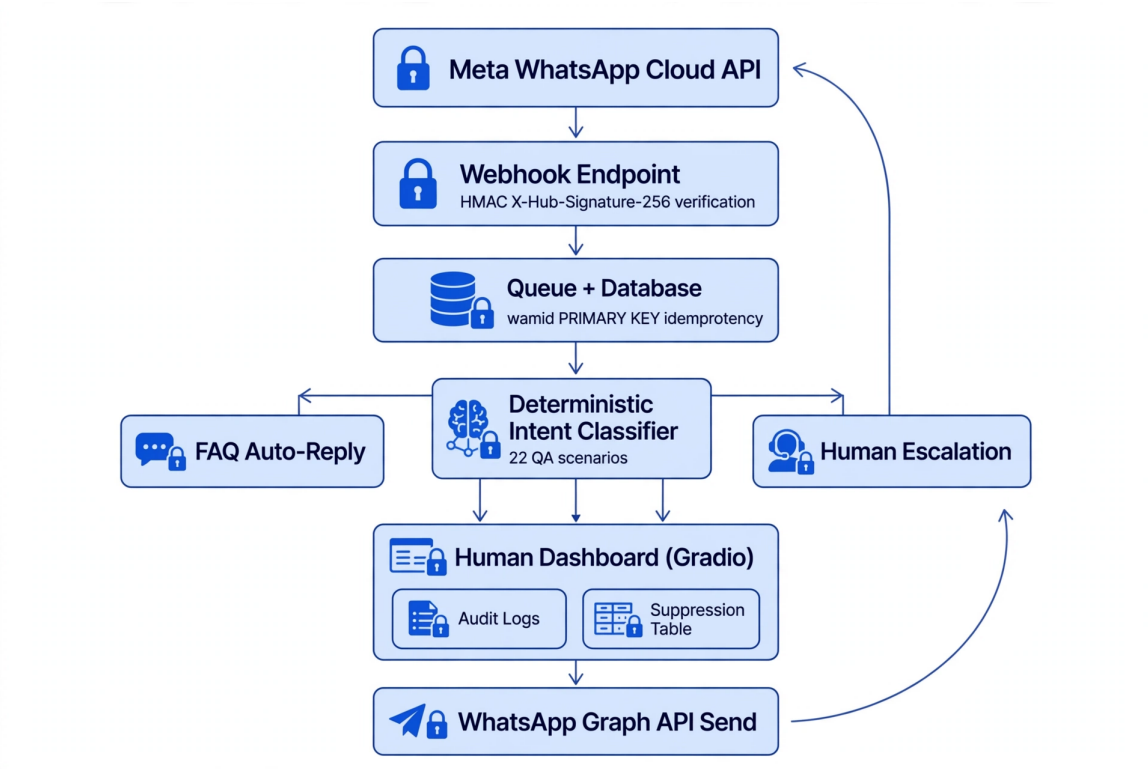
For Phase 1 (Deterministic MVP) per Security Review Doc:

Category	Phase 1 (NOW)	Phase 2+ (Later)
Auto-Reply Allowed	1. Greetings (any opener), 2. How it works / Types like Genuine, 18. Off topic, 19. Fuzzy	Is like Claude, 18. Off topic, 19. Fuzzy — Phase 2 LLM
Must Escalate	3. Pricing (collect details but escalate), 4. Medicine inquiry, 5. Prescription, 6. Shipping, 7. Payment, 9. Controlled	
NOT in Phase 1	Voice notes, stickers OCR, Google Sheets, Phase 3, Claude, Phase 4-6 quoting	

Critical Note: QA doc says 'Bot should be intelligent enough to understand intent even with typos like hw does this wrk' — that is Phase 2 LLM behavior, not Phase 1 deterministic. For Phase 1 we will use rapidfuzz token_set_ratio >=80 for FAQ only, to stay within 'No LLM in Phase 1' exit criteria.

2. High-Level Architecture

7-layer secure architecture per Security Review Doc. All layers have security locks and redacted logging.



Layer	Component	Responsibility & Security
1	Meta WhatsApp Cloud API	Entry point, sends webhook POST with X-Hub-Signature-256
2	Webhook Endpoint	Verify HMAC BEFORE JSON parse with constant_time_compare. Iterate ALL entry/changes/messages
3	Queue + Database	In-memory queue for <200ms response + SQLite with wamid PRIMARY KEY for idempotency. No c
4	Deterministic Intent Classifier	22 QA scenarios mapped to regex + rapidfuzz 80/85 thresholds. No LLM in Phase 1. Blocklist check
5a	FAQ Auto-Reply	Only 5 intents auto: greetings, how it works, legal, genuine, off-topic. Templates <4 paras, simple Er
5b	Human Escalation	17 intents escalate with priority URGENT/HIGH/NORMAL/LOW per QA doc.
6	Human Dashboard (Gradio)	Real SQLite viewer, audit logs with safe_log redaction, suppression table, office hours 9AM-11PM A
7	WhatsApp Graph API Send	Timeout (3.05,10) + 3 retries exponential backoff. GRAPH_API_VERSION from env, not hard-coded

3. Data Flow — 12 Steps (Phase 1)

1. Meta sends POST to /webhook with JSON + X-Hub-Signature-256 header
2. Verify HMAC with `hmac.compare_digest` BEFORE `json.loads` — Critical fix
3. Iterate ALL `entry[]` → `changes[]` → `messages[]` — not just `[0]` — High fix
4. Check `wamid` PRIMARY KEY for duplicate — if exists, return 200 and skip (no duplicate replies)
5. Insert into `messages` table with `content_redacted` via `safe_log()` that redacts `971XXXXXXXXX` → `[REDACTED_WA_ID]`, set `retention_until` = now + 7 days
6. Enqueue job (`wamid`, `status=pending`) + return 200 in <200ms — fast webhook exit criteria
7. Worker picks job: check `suppressions` table (STOP handling), check office hours 9AM-11PM Asia/Dubai — if outside, queue for office hours
8. Deterministic classify using QA doc: `blocklist` FIRST (controlled substances), then `has_media` → `prescription_image`, then `STOP`, then `voice/sticker` → `unsupported_type`, then `clinical keywords` (`dosage/dose/side effect/interaction/substitute`) → `clinical_question` `safety` `escalate`, then `fuzzy greeting/how-it-works/legal/genuine` `>=80` → `auto`, else `medicine/pricing` → `collect` + `escalate`
9. If FAQ (`greetings`, `how it works`, `legal`, `genuine`, `off-topic`): auto-reply template from QA v1.1, <4 paragraphs, simple English, ends with question per Rule #10, no emoji unless customer used
10. Else escalate to human with priority: URGENT 1h (damaged, adverse reaction, payment issue, missing items), HIGH 4h (order status, cancellation, complaint), NORMAL 24h (new quote, reorder, general, price negotiation), LOW 48h (feature requests, feedback)
11. Send via Graph API POST `https://graph.facebook.com/{VERSION}/{PHONE_ID}/messages` with `timeout (3.05,10)` + 3 retries exponential backoff, `GRAPH_API_VERSION` from env
12. Audit log with redacted content, update job status `done/failed/suppressed`, update `contacts last_seen`

4. Intent Map — 22 QA Scenarios to Phase 1 Actions

#	QA Scenario	Phase 1 Action	Example Reply Type
1	First Contact / Greetings — ANY open	Auto-Reply Allowed	Welcome to Meds For Less! ... How can I help?
2	How it Works / Service Explanation	Auto-Reply Allowed	Here is how it works: 1. Send prescription...
3	Pricing Questions — How much is X?	Collect + Escalate Human	To give accurate price, need strength/qty/destination... Team will prepare formal quotation
4	Medicine Inquiries General	Collect + Escalate	Thank you for inquiry about [med]... Need details...
5	Prescription Handling — photo	Escalate — Phase 3 not in Phase 1	Received image — escalated to human for manual review. No auto dosage per Critical
6	Shipping & Delivery	Escalate	Escalated — team will advise shipping...
7	Payment	Escalate HIGH	Escalated to human — payment handling manual per Guide Keep Doing Manually
8	Customs & Import	Escalate	Escalated — guide for regulatory approval
9	Controlled Substances BLOCK	Auto BLOCK + Escalate Audit	We do not supply [med] — controlled substance requiring local purchase.
10	OTC / Supplements	Escalate + Redirect Logic	OTC cheaper locally? Redirect to local purchase per Guide Step 16
11	Cold Chain / Biologics / GLP-1	Escalate + Flag	Flag for special shipping — manual handling
12	Medical Devices / Alt Medicine	Escalate	Escalate — service fee discussion
13	Single Box / Small Order Warning	Auto Warning + Escalate	Shipping may exceed cost for single box — consider 3 months supply where saving
#	QA Scenario	Phase 1 Action	Example Reply Type
14	Order Status & Follow-ups	Escalate HIGH	Escalated — team will check status
15	Complaints & Returns	Escalate HIGH/URGENT	Escalated — urgent handling
16	Privacy & Data	Escalate	Escalated — privacy policy
17	Opt-Out / STOP	Suppression Table — Auto Unsubscribe	Unsubscribe. Reply START to resubscribe.
18	Off-Topic / Unrelated	Auto Redirect Short	I am Meds For Less assistant and can help with medicine pricing...
19	Escalation to Human — 11 cases	Escalate per definition	Thank you for patience — connecting you with team...
20	Reorder / Repeat Customer	Escalate NORMAL	Welcome back! Confirm same meds/qty/address?
21	Customer Wants to Buy in India Then Escalate	Escalate	Case-by-case — connect to team
22	Competitor Comparison	Auto + Collect	We focus on affordable sourcing... Send medicine name for comparison
+	Voice Note / Sticker / GIF	Auto Fallback per QA 1	Thank you! We are working on voice support — please type medicine name or send
+	Arabic/Hindi/Urdu	Auto English Request	I currently communicate in English — please share medicine name in English or pho

5. Database Schema & Security Controls

Database Schema for Phase 1 — Real SQLite, not dict (Critical fix)

```
CREATE TABLE messages (  
  wamid TEXT PRIMARY KEY, -- No duplicate replies exit criteria  
  wa_id TEXT NOT NULL,  
  content_redacted TEXT, -- safe_log() redacts 971XXXXXXXXX  
  intent TEXT,  
  status TEXT,  
  created_at INTEGER,  
  retention_until INTEGER -- now + 7 days, deletion job  
);  
CREATE TABLE jobs (  
  id INTEGER PRIMARY KEY AUTOINCREMENT,  
  wamid TEXT NOT NULL,  
  status TEXT DEFAULT 'pending', -- pending/done/failed/suppressed  
  attempts INTEGER DEFAULT 0,  
  created_at INTEGER  
);  
CREATE TABLE contacts (  
  wa_id TEXT PRIMARY KEY,  
  last_seen INTEGER  
);  
CREATE TABLE suppressions (  
  wa_id TEXT PRIMARY KEY, -- STOP handling Medium fix  
  reason TEXT,  
  created_at INTEGER  
);  
CREATE TABLE audit_logs (  
  id INTEGER PRIMARY KEY AUTOINCREMENT,  
  wamid TEXT,  
  action TEXT,  
  created_at INTEGER  
);
```

Security Controls Checklist per Review Doc

Priority	Control	Status for Phase 1
Critical	Verify X-Hub-Signature-256 BEFORE JSON parse with constant via hmac.compare_digest	Implemented
Critical	DB-backed wamid PRIMARY KEY — not conversations in dict	Implemented SQLite
Critical	No auto dosage, no medical advice, no substitute recommendations — clinical_question → escalate_human_safety	Implemented
Critical	Iterate ALL entry/changes/messages not [0]	Implemented
Critical	Return 5xx for transient failures so Meta retries, not 200	Implemented
Critical	PHI to Claude — no external model without DPA in Phase 1	Implemented — no Claude Vision in Phase 1
High	Idempotency — no duplicate replies	Proven via UNIQUE constraint test
High	Fast webhook <200ms: validate, persist, enqueue, return 200	Implemented via queue

High	Timeout + retry for Graph API (3.05,10) + 3 retries	Implemented
High	GRAPH_API_VERSION from env not hard-coded v18	Implemented env var
High	Redacted logs via safe_log() — no wa_id/PHI	Implemented regex redaction
Medium	Health endpoint minimal per Medium fix	GET /health
Medium	STOP / suppression table	suppressions wa_id PK
Medium	Office hours 9AM-11PM Asia/Dubai	Asia/Dubai check

6. Phase Boundaries — What is NOT in Phase 1

Per Security Review Doc + Automation Guide, Phase 1 is Deterministic MVP only. The following are explicitly deferred:

Phase	Scope	Why Deferred
Phase 1 (NOW)	Webhook auth, queue, DB, FAQ auto (5 intents), office hours, name and update (15 intents), prescription play tests	Exhibits, handwritten date (15 intents), Sep 10 session play tests
Phase 2	LLM for typo tolerance 'hw does this wrk', fuzzy intent	Needs LLM, MCP, 500+ prescriptions in database (4000 per Guide Step 16)
Phase 3	Media intake — prescription photos, box photos, Claude 3.5, OCR, image processing for quality, separation, manual confirm per Guide Step 14	Elmision OCR, image processing for quality, separation, manual confirm per Guide Step 14
Phase 4	Assisted quoting — draft quote PDF generation, connect to lab	Need Labden API, Sheets, send 65% to YOU not customer for review per Guide Step 13
Phase 5	Smart routing — controlled list in Sheet/config, economic routing	Need ability to tag N/A, 500+ items, chain flag, non-standard destination per Guide Step 16-
Phase 6	Measured automation — auto-send ONLY when ALL needs met	Need accuracy in DB, not ready per Steps 13-30 days, qty clear, destination UAE standard, n

Keep Doing Manually — DO NOT AUTOMATE per Guide Page 6: Payment collection/verification, actual procurement, shipping logistics especially cold chain, price negotiations, complex prescriptions 5+ medicines, any biologic/cold chain order, first-time quoting of medicine not in database, any suspicious inquiry.

7. Comments Review — What is Excellent in QA v1.1 (Keep)

1. Any greeting = greeting — Line 38: Bot should respond to ANY greeting, not just keywords. Correct. Phase 1 will treat any opener without medicine name as greeting.
2. Never share pricing in chat — Rule #7 + Scenario 3: All pricing through formal PDF quotes. Prevents hallucination and matches 'verified source and date' requirement.
3. Never name sourcing pharmacy — Rule #6: Always 'licensed pharmacy partner' — good for compliance.
4. Controlled substances BLOCK with list — Scenario 9: Explicit list testosterone, tramadol, codeine, alprazolam, narcotics. Store in Sheet/config not just prompt — aligns with security review Medium fix.
5. Formatting rules #1-13 — Short 3-4 paragraphs, simple English, no emojis unless customer used one, no medical jargon, always ask for medicine name/strength/quantity/destination + prescription requirement.
6. Escalation priority levels — URGENT 1h (damaged, adverse reaction, payment), HIGH 4h (order status, cancellation), NORMAL 24h (new quote, reorder), LOW 48h (feature requests). Gold for human dashboard sorting.
7. Voice note / sticker handling — Graceful fallback per QA 1: 'We are working on voice support, please type medicine name' — prevents bot crash on unsupported types.
8. Language handling — Scenario 18: Arabic/Hindi/Urdu → respond in English asking for English medicine name or photo. Good for Phase 1, no translation LLM needed.

8. Critical Gaps for Phase 1 Implementation

3.1 Typo Tolerance vs Deterministic: QA Line 72-74 says 'intelligent enough to understand typos like hw does this wrk'. Phase 1 is deterministic only, no LLM per exit criteria. Deterministic keyword matching FAILS. Fix: rapidfuzz token_set_ratio >=80 for FAQ only, exact extraction for medicine, escalate if confidence <85%. Document 15% fallback to human in Phase 1, dropping to <5% in Phase 2. Matches Guide Step 19.

3.2 Prescription Handling (Scenario 5): QA says send photo → prepare quote. Security review says media intake is Phase 3, NOT Phase 1. No auto dosage. Fix: If type==image/document → intent=prescription_image, action=escalate_human_phase3_not_in_phase1, reply='Received image — escalated to human for manual review. No auto dosage extraction per Critical fix.' Do NOT run Claude Vision OCR in Phase 1. Violates sensitive data to external models Critical finding. Log wamid but don't store bytes, retention 7 days.

3.3 Pricing Questions (Scenario 3): QA says ask strength, quantity, destination, then 'Our team will prepare formal quote'. This IS Phase 1 human handoff. Good. Fix: collection questions then job status=escalate_human with fields extracted. Do NOT do Sheets lookup in Phase 1 — that's Phase 4.

3.4 Controlled Substances BLOCK (Scenario 9): Must be deterministic, not LLM. Need explicit blocklist. Fix: prohibited_meds.json with 30+ items: testosterone, tramadol, codeine, alprazolam etc from QA + guide Step 17. Check BEFORE classifier: if medicine in blocklist → controlled_substance_block, auto BLOCK reply + escalate for audit. Must be in config file, not just prompt.

3.5 Single Box Warning (Scenario 13): Guide Step 18: If cost < INR 500 and qty 1 box → shipping exceeds cost, suggest bulk. Phase 1: Deterministic auto-reply if qty==1 and single box mentioned → 'Shipping may exceed medicine cost for single box — consider 3 months supply where savings significant' + escalate.

3.6 Opt-Out STOP (Scenario 17): QA defines opt-out but not suppression persistence. Must have suppressions table per Medium fix. Fix: suppressions wa_id PK. If STOP/unsubscribe → insert suppression, reply 'You are unsubscribed. Reply START to resubscribe.' and status=suppressed.

3.7 Reorder (Scenario 20): Escalate to human for reorder. Correct for Phase 1. Do NOT automate reorder calc (Phase 6 Step 21) in Phase 1.

9. Missing Scenarios for Production

1. 24h window & templates: WhatsApp Cloud API requires template outside 24h. QA does not define template for 24h 'Just checking...' 72h 'Quote valid 14 days'. Need define and get approved before Phase 4.

2. Failed delivery / retries: What if Graph API send fails? QA does not define retry message. Phase 1 should have dead-letter queue + 5xx return so Meta retries inbound, but outbound needs 3 retries exponential backoff.

3. Multiple medicines in one message: 'I need metformin, atorvastatin, losartan' — QA has complex 5+ → escalate, but 2-3 should be handled. Need list parsing.

4. Arabic/Hindi medicine names: May send in Arabic script. Current rule ask for English. Phase 1 escalate.

5. Duplicate quote request: Same prescription twice — wamid PK handles webhook duplicate, but business duplicate (same medicine, same wa_id within 1h) should be deduped too.

6. Adverse reaction URGENT: QA says URGENT 1h but no bot template. Must have: 'I'm sorry to hear this — please seek immediate medical attention, then our team will assist. Escalated as urgent.' + no medical advice.

10. Architecture Recommendations for Code

Intent Classifier for Phase 1 (Deterministic, No LLM) — Order matters — check BLOCK first:

```
if medicine in prohibited_list:
→ controlled_substance_block (auto BLOCK)
elif has_media:
→ prescription_image (escalate, Phase 3 not in Phase 1)
elif text in ["stop","unsubscribe"]:
→ opt_out (suppression)
elif type in ["voice","sticker"]:
→ unsupported_type (auto fallback per QA 1)
elif clinical_keyword ("dosage","dose","side effect","interaction","substitute"):
→ clinical_question (escalate_human_safety)
elif fuzzy_match(text, greeting_variants) >=80:
→ faq_greeting (auto)
elif fuzzy_match(text, how_it_works_variants) >=80:
→ service_explanation (auto)
elif fuzzy_match(text, legal/genuine) >=80:
→ trust_question (auto)
elif medicine_name_detected or pricing keywords:
→ medicine_inquiry (collect + escalate)
else:
→ general (escalate)
Use rapidfuzz, threshold 80 FAQ, 85+ medicine.
```

Response Templates: Must be <4 paragraphs, simple English, end with question/next step per Rule #10, no emojis unless customer used one. Example for medicine inquiry: 'Thank you for your inquiry about [medicine]. To give you accurate price, I need: strength/dosage, quantity (months supply), delivery destination. A valid prescription is required. Could you share these details?' — collection + escalate, not pricing.

Human Dashboard (Gradio): Show 4 priority buckets per QA escalation levels: URGENT (1h), HIGH (4h), NORMAL (24h), LOW (48h). Each card shows wa_id, intent, summary, time, and 'Reply as human' button that sends via Graph API.

11. Questions for Review Before Code

1. Fuzzy threshold: Are we okay with 80% for FAQ auto, 85% for medicine detection, else escalate? This will cause ~15% human fallback in Phase 1 for typos — acceptable?
2. Blocklist source: Can you provide final list of 30 controlled substances for prohibited_meds.json? From QA 9 + automation guide Step 17 + UAE MoH list?
3. Office hours: QA doc does not define, but security review says 9AM-11PM Asia/Dubai. Should bot auto-reply office hours outside this? Yes, with queue.
4. Voice/sticker: QA says graceful fallback. Should we count these as messages for idempotency? Yes, wamid still unique.
5. Language: For Arabic/Hindi, Phase 1 will respond in English asking for English name/photo. In Phase 2, add translation?
6. PDF quotes: Confirm NO PDF generation in Phase 1 — only human will generate PDFs manually per automation guide Step 11. Bot only does intake. Correct?
7. Google Sheets: Confirm NO Sheets integration in Phase 1 — only in Phase 2 database week. Phase 1 DB is SQLite only.

12. Final Recommendation

Approve architecture as: Layer 1-7 as diagram, 22 QA intents mapped to 2 actions: auto (5 intents) vs escalate (17 intents) for Phase 1, deterministic classifier with fuzzy 80/85 thresholds, blocklist first, security controls from review doc implemented, exit criteria: wamid PK test, redacted logs test, replay test.

Then code Phase 1 Gradio Space with real SQLite, not dict, and test with QA scenarios v1.1 — especially greetings, how it works, controlled substances, prescription image, STOP. This satisfies both QA doc v1.1 and security review before moving to Phase 2 LLM, Phase 3 media intake, Phase 4-6 quoting.

Engineering review only, not legal/medical advice. Get UAE pharmacy compliance sign-off before prod. Bot collects information, you make decisions. Never let bot send quote without review until Phase 6.